

BÁO CÁO TUẦN 2

1. Dataset đã chọn và lý do

1.1. Dataset ứng viên

Dataset được chọn: "SQL Injection Detection by Machine Learning" (file Modified_SQL_Dataset.csv) trên Kaggle, đã được sử dụng và kiểm chứng trong ít nhất một công bố khoa học uy tín (Peralta-Garcia và cộng sự, 2024, tạp chí Informatics/MDPI).

1.2. Đối chiếu tiêu chí chốt dataset

Tiêu chí	Yêu cầu	Kết quả thực tế	Đạt?
Số lượng mẫu	> 30.000	30.919 dòng (30.907 sau loại trùng)	Đạt
Gán nhãn nhị phân	Rõ ràng, 2 lớp	Label $\in \{0, 1\}$, không có giá trị thiếu	Đạt
Tỷ lệ 2 lớp	Không lệch quá 30/70	Lớp 0: 63,18% — Lớp 1: 36,82%	Đạt (sát ngưỡng)
Trùng lặp	Không trùng lặp nặng	12/30.919 dòng trùng (~0,04%)	Đạt

Nhận xét: dataset đạt cả 4 tiêu chí đã đặt ra ở kế hoạch Tuần 2. Tỷ lệ trùng lặp gần như không đáng kể (12 dòng), không ảnh hưởng đến quy mô mẫu. Tỷ lệ nhãn 63/37 nằm trong ngưỡng cho phép nhưng vẫn thể hiện mất cân bằng lớp nhất định — cần lưu ý xử lý ở Tuần 4.

1.3. Kiểm tra giá trị thiếu (null)

Kết quả kiểm tra trên 2 cột Query và Label: không phát hiện giá trị null ở cả hai cột, dữ liệu sạch về mặt thiếu sót.

1.4. Chia tập train/test

Dataset sau khi loại trùng (30.907 dòng) được chia theo tỷ lệ 80/20, có stratify theo nhãn để giữ nguyên phân bố lớp giữa 2 tập, cố định random_state=42:

Tập	Số dòng	Tỷ lệ lớp 0	Tỷ lệ lớp 1
Train	24.724	63,19%	36,81%
Test	6.181	63,18%	36,82%

Tỷ lệ nhãn giữa train và test gần như đồng nhất (chênh lệch dưới 0,01%), xác nhận việc stratify hoạt động đúng. Cặp train.csv/test.csv này được cố định (random_state=42) và sẽ tái sử dụng xuyên suốt Tầng 1, 2, 3 ở các tuần sau để đảm bảo so sánh công bằng giữa các mô hình, không random chia lại.

1.5. Kiểm tra nhãn thủ công (sample check)

Lấy mẫu ngẫu nhiên 25 dòng (random_state=42) để đọc và đối chiếu thủ công giữa nội dung câu truy vấn và nhãn được gán. Kết quả: toàn bộ 25 dòng có nhãn phù hợp với nội dung câu truy vấn, không phát hiện trường hợp gán nhãn sai. Đây là cơ sở để yên tâm sử dụng dataset xuyên suốt các tuần tiếp theo mà không cần làm sạch lại nhãn.

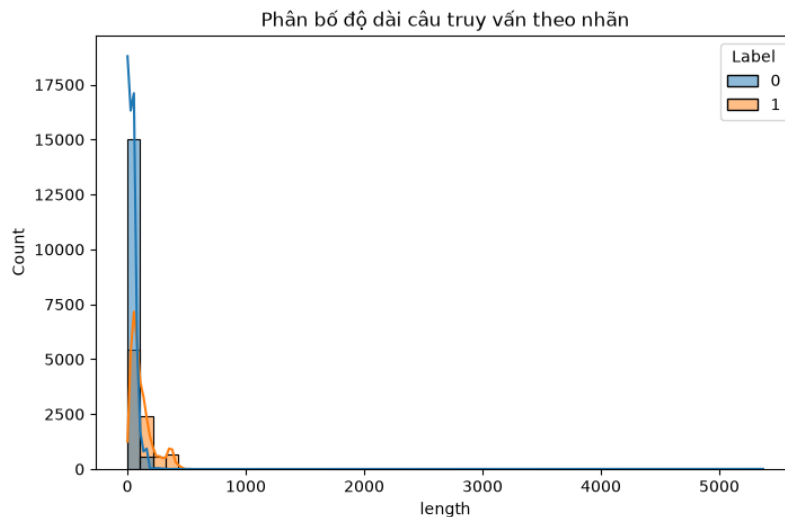
1.6. Quyết định

Chọn Modified_SQL_Dataset.csv làm dataset chính thức cho toàn bộ đồ án, dựa trên việc dataset đạt đầy đủ 4 tiêu chí đề ra, có nguồn gốc rõ ràng (đã được dùng trong nghiên cứu công bố), và đã được xác minh chất lượng nhãn qua kiểm tra thủ công.

2. Thống kê mô tả dữ liệu

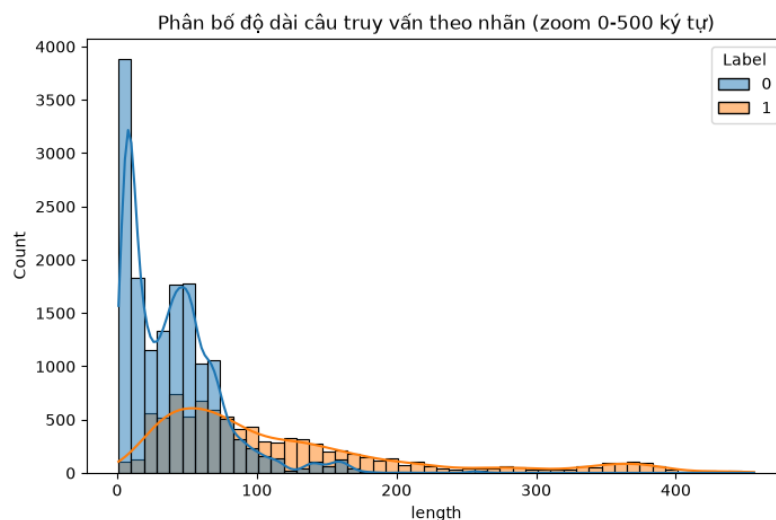
Toàn bộ thống kê trong mục này được tính trên tập train (24.724 dòng) để tránh rò rỉ thông tin từ tập test sang giai đoạn phân tích/thiết kế đặc trưng.

2.1. Phân bố độ dài câu truy vấn



Hình 1. Phân bố độ dài câu truy vấn theo nhãn (toàn khoảng giá trị)

Biểu đồ ban đầu bị nén do một số câu truy vấn hợp lệ (nhãn 0) có độ dài ngoại lệ lên đến 5.370 ký tự, trong khi phần lớn dữ liệu tập trung dưới 500 ký tự. Do đó, biểu đồ được zoom lại để quan sát rõ vùng phân bố chính:



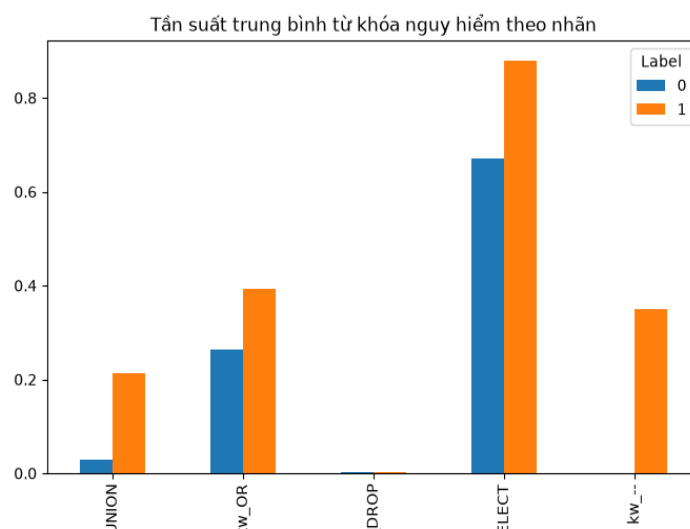
Hình 2. Phân bố độ dài câu truy vấn theo nhãn (zoom 0-500 ký tự)

Nhãn	Số lượng	Trung bình	Độ lệch chuẩn	Trung vị (50%)	Min	Max
0 (hợp lệ)	15.622	39,89	54,98	35	1	5.370
1 (SQL Injection)	9.102	118,74	96,65	86	1	456

Nhận xét: câu truy vấn SQL Injection (nhãn 1) dài hơn rõ rệt so với câu hợp lệ — trung bình 118,74 ký tự so với 39,89 ký tự (gấp gần 3 lần), trung vị cũng cao hơn gần 2,5 lần (86 so với

35). Điều này phù hợp với đặc điểm kỹ thuật của tấn công SQLi: payload thường phải chèn thêm cú pháp (UNION SELECT, điều kiện OR, comment...) khiến câu truy vấn dài hơn đáng kể so với truy vấn nghiệp vụ thông thường. Đáng chú ý, giá trị max ở nhãn 0 (5.370) là một outlier cực đoan so với phần còn lại của lớp này — cần kiểm tra riêng dòng dữ liệu này ở bước làm đặc trưng, tránh để nó chi phối việc chuẩn hóa (scaling) đặc trưng length ở Tầng 1.

2.2. Tần suất từ khóa nguy hiểm



Hình 3. Tần suất trung bình từ khóa nguy hiểm theo nhãn

Từ khóa	Nhãn 0 (hợp lệ)	Nhãn 1 (SQLi)	Chênh lệch
UNION	0,0285	0,2124	~7,4 lần
OR	0,2630	0,3918	~1,5 lần
DROP	0,0028	0,0034	Không đáng kể
SELECT	0,6705	0,8783	~1,3 lần
-- (comment)	0,0001	0,3492	~2.730 lần

Nhận xét: "--" (dấu comment) là từ khóa phân biệt mạnh nhất trong nhóm này — gần như không xuất hiện ở câu hợp lệ (0,0001) nhưng có mặt ở khoảng 35% câu SQLi. UNION cũng có khả năng phân biệt tốt (chênh lệch ~7,4 lần), phù hợp với vai trò đặc trưng của kỹ thuật UNION-based injection. Ngược lại, SELECT và DROP có mặt ở cả 2 lớp với tỷ lệ khá gần nhau — SELECT vì đây là từ khóa phổ biến trong mọi câu truy vấn hợp lệ, còn DROP có tần suất quá thấp ở cả 2 lớp (dưới 0,4%) nên không đóng góp nhiều cho việc phân loại nếu dùng riêng lẻ.

2.3. Tần suất ký tự đặc biệt cơ bản

Ký tự	Nhãn 0	Nhãn 1	Chênh lệch (lớp 1 / lớp 0)
' (nháy đơn)	0,6615	1,1284	~1,7 lần
; (chấm phẩy)	0,0322	0,0073	~0,23 lần (thấp hơn ở lớp 1)
= (dấu bằng)	0,2089	1,2057	~5,8 lần
-- (comment)	0,0001	0,3492	~2.730 lần

Điểm đáng chú ý: dấu chấm phẩy (;) có tần suất thấp hơn ở câu SQL Injection (0,0073) so với câu hợp lệ (0,0322) — ngược với giả định ban đầu rằng ký tự đặc biệt càng nhiều thì càng có khả năng là tấn công. Nguyên nhân khả dĩ là các payload SQLi trong dataset chủ yếu thuộc dạng chèn điều kiện vào mệnh đề WHERE hiện có (không cần kết thúc câu bằng dấu

chấm phẩy để mở câu lệnh mới), trong khi một số câu truy vấn hợp lệ trong dataset có thể chứa nhiều lệnh nối tiếp nhau bằng dấu chấm phẩy. Đây là lý do không nên đưa ký tự này vào nhóm đặc trưng "nguy hiểm" mà không kiểm chứng số liệu.

2.4. Tần suất ký tự đặc biệt mở rộng

Ký tự / nhóm	Nhãn 0	Nhãn 1	Tỷ lệ chênh lệch
, (dấu phẩy)	0,3354	1,8087	~5,39 lần
((ngoặc mở)	0,2917	3,5400	~12,14 lần
) (ngoặc đóng)	0,2861	3,9889	~13,94 lần
% (phần trăm)	0,0300	0,1968	~6,55 lần
Comment markers tổng hợp (--, #, /* */)	0,00064	0,5256	~819,8 lần

Nhận xét: nhóm ký tự mở rộng cho kết quả rất tích cực. "Comment markers tổng hợp" là đặc trưng phân biệt mạnh nhất trong toàn bộ EDA (chênh lệch ~820 lần), xác nhận giả thuyết đặt ra trước đó rằng việc gộp --, # và /* */ vào một đặc trưng tổng hợp nắm bắt tốt kỹ thuật "comment-out phần còn lại của câu lệnh" — một trong những kỹ thuật SQLi phổ biến nhất. Ngoặc đơn/ngoặc kép (12–14 lần) và dấu phẩy (5,4 lần) cũng thể hiện khả năng phân biệt tốt, phù hợp với kỹ thuật UNION-based injection (liệt kê nhiều cột bằng dấu phẩy) và function-based injection (SLEEP(), CONCAT(...)). Toàn bộ nhóm ký tự mở rộng này nên được đưa vào danh sách đặc trưng thủ công chính thức cho Tầng 1.

2.5. Đặc trưng cấu trúc câu

Đặc trưng	Nhãn 0	Nhãn 1	Nhận xét nhanh
Tỷ lệ chữ hoa (uppercase_ratio)	0,2372	0,0039	Thấp hơn rõ rệt ở lớp 1
Số khoảng trắng (n_whitespace)	6,54	43,99	Cao hơn ~6,7 lần ở lớp 1
Số chữ số (n_digit)	1,71	18,32	Cao hơn ~10,7 lần ở lớp 1

Đây là phát hiện đáng chú ý nhất của toàn bộ EDA: tỷ lệ chữ hoa ở câu SQL Injection (0,39%) thấp hơn nhiều so với câu hợp lệ (23,72%) — ngược hoàn toàn với giả định thường gặp rằng từ khóa SQL trong payload tấn công (UNION, SELECT, OR...) thường được viết hoa. Khả năng cao là các payload trong dataset này chủ yếu ở dạng chữ thường (tự động sinh bởi công cụ quét lỗ hổng), trong khi câu truy vấn hợp lệ có xu hướng chứa nhiều thành phần định danh viết hoa (tên bảng, tên cột theo convention, hoặc dữ liệu văn bản có in hoa). Đây là ví dụ cụ thể cho thấy tầm quan trọng của việc kiểm chứng bằng số liệu thay vì suy luận chủ quan khi thiết kế đặc trưng — nếu không có bước EDA này, đặc trưng uppercase_ratio có thể bị gán sai chiều tác động hoặc bị loại bỏ nhầm. Số khoảng trắng và số chữ số đều cao hơn đáng kể ở lớp 1, phù hợp với việc câu SQLi dài hơn và thường chứa nhiều giá trị số (trong điều kiện OR 1=1, giới hạn LIMIT, offset...).

3. Danh sách đặc trưng thủ công dự kiến cho Tầng 1

Dựa trên kết quả EDA ở mục 2, danh sách đặc trưng thủ công được điều chỉnh so với dự kiến ban đầu: giữ lại các đặc trưng có chênh lệch rõ rệt giữa 2 lớp, gộp một số đặc trưng liên quan để tránh phình số lượng, và loại/hạ ưu tiên các đặc trưng không thể hiện khả năng phân biệt trong số liệu thực tế.

3.1. Nhóm đặc trưng độ dài và cấu trúc

- length — độ dài câu truy vấn (ký tự). Căn cứ: chênh lệch trung bình ~3 lần giữa 2 lớp.
- uppercase_ratio — tỷ lệ chữ hoa. Căn cứ: chênh lệch rõ rệt (23,72% so với 0,39%), tuy ngược hướng giả định ban đầu nhưng có tín hiệu phân biệt mạnh.
- n_whitespace — số khoảng trắng. Căn cứ: chênh lệch ~6,7 lần.
- n_digit — số lượng chữ số. Căn cứ: chênh lệch ~10,7 lần.

3.2. Nhóm đặc trưng ký tự đặc biệt

- n_quote — số dấu nháy đơn ('). Căn cứ: chênh lệch ~1,7 lần.
- n_equal — số dấu bằng (=). Căn cứ: chênh lệch ~5,8 lần.
- n_comma — số dấu phẩy (,). Căn cứ: chênh lệch ~5,4 lần, gắn với kỹ thuật UNION-based injection.
- n_paren — tổng số ngoặc đơn mở và đóng. Căn cứ: chênh lệch ~12–14 lần, gắn với kỹ thuật function-based injection (SLEEP(), CONCAT(...)).
- n_percent — số dấu phần trăm (%). Căn cứ: chênh lệch ~6,55 lần, có thể liên quan đến LIKE-based injection hoặc payload URL-encoded.
- n_comment_markers — tổng hợp số lượng --, # và /* */. Căn cứ: đặc trưng phân biệt mạnh nhất trong toàn bộ EDA (chênh lệch ~820 lần).

3.3. Nhóm đặc trưng từ khóa nguy hiểm (dạng binary hoặc đếm)

- has_union — có chứa UNION hay không. Căn cứ: chênh lệch ~7,4 lần.
- has_or — có chứa OR hay không. Căn cứ: chênh lệch ~1,5 lần, mức phân biệt trung bình.
- has_select_from — có chứa cấu trúc SELECT...FROM hay không (thay vì chỉ đếm SELECT đơn lẻ, để tránh nhiễu vì SELECT phổ biến trong cả câu hợp lệ).
- keyword_repeat_count — tổng số lần lặp lại các từ khóa nguy hiểm trong một câu.

3.4. Đặc trưng cân nhắc loại bỏ hoặc hạ ưu tiên

- has_drop — tần suất DROP quá thấp ở cả 2 lớp (dưới 0,4%), gần như không đóng góp cho phân loại nếu dùng riêng lẻ. Có thể giữ lại với vai trò hỗ trợ nhưng không kỳ vọng nhiều.
- n_semicolon — số dấu chấm phẩy (;). Số liệu thực tế cho thấy chiều tác động ngược với giả định (thấp hơn ở lớp SQLi), cân nhắc loại khỏi Tầng 1 hoặc giữ lại như một đặc trưng kiểm tra chứ không phải đặc trưng chính.

Tổng số đặc trưng đề xuất: 15 đặc trưng (4 đặc trưng cấu trúc + 6 đặc trưng ký tự đặc biệt + 4 đặc trưng từ khóa + 1 đặc trưng tổng hợp lặp từ khóa), khớp với ngân sách 15 đặc trưng đã đặt ra trong kế hoạch Tuần 2. n_semicolon và has_drop được giữ lại như đặc trưng hỗ trợ có thể loại bỏ sau khi đánh giá độ quan trọng đặc trưng (feature importance) ở Tuần 4.

4. Nhận định ban đầu về đặc trưng phân biệt

4.1. Đặc trưng có khả năng phân biệt mạnh nhất

Theo thứ tự chênh lệch giữa 2 lớp (từ mạnh đến trung bình):

- `n_comment_markers` (~820 lần) — mạnh nhất, kỳ vọng đóng góp lớn nhất vào độ chính xác của Random Forest/SVM.
- `n_paren` (~12–14 lần) và `uppercase_ratio` (chênh lệch tuyệt đối rất lớn dù tỷ lệ khác hướng) — nhóm phân biệt mạnh thứ hai.
- `n_digit` (~10,7 lần), `n_percent` (~6,55 lần), `n_equal` (~5,8 lần), `n_comma` (~5,4 lần) — nhóm phân biệt khá.
- `has_union` (~7,4 lần), `length` (~3 lần), `n_whitespace` (~6,7 lần) — nhóm phân biệt trung bình nhưng ổn định, ít khả năng bị nhiễu bởi outlier.

4.2. Rủi ro và lưu ý khi bước sang Tầng 1 (Tuần 4)

- Outlier độ dài: câu hợp lệ dài nhất lên tới 5.370 ký tự trong khi phần lớn dữ liệu dưới 500 ký tự — cần kiểm tra và cân nhắc xử lý (loại bỏ hoặc giới hạn) trước khi scale đặc trưng `length`, tránh outlier chi phối `StandardScaler/MinMaxScaler`.
- Mất cân bằng lớp (63/37): dù trong ngưỡng cho phép, vẫn cần áp dụng `class_weight` hoặc SMOTE ở Tuần 4 như kế hoạch đã định, và ưu tiên báo cáo theo Precision/Recall/F1 thay vì Accuracy để tránh đánh giá sai lệch.
- Hai đặc trưng "ngược hướng giả định" (`uppercase_ratio`, `n_semicolon`) là minh chứng cho thấy không nên thiết kế đặc trưng thuần túy dựa trên kiến thức lý thuyết về SQLi mà cần đối chiếu với đặc điểm cụ thể của dataset đang dùng — cùng một đặc trưng có thể mang chiều tác động khác nhau tùy nguồn dữ liệu.
- `SELECT` và `DROP` có tần suất gần nhau giữa 2 lớp — nên kết hợp các từ khóa này trong đặc trưng ngữ cảnh (`has_select_from`) thay vì dùng đếm từ khóa đơn lẻ, để tránh đưa vào mô hình những đặc trưng nhiễu, ít giá trị phân biệt.

4.3. Kết luận

Bộ 15 đặc trưng thủ công đề xuất ở mục 3 có cơ sở định lượng vững chắc từ kết quả EDA, bao phủ đầy đủ các khía cạnh: độ dài/cấu trúc câu, ký tự đặc biệt liên quan trực tiếp đến kỹ thuật injection phổ biến (UNION-based, comment-based, function-based), và từ khóa nguy hiểm. Đây là nền tảng đủ tốt để triển khai `extract_features()` và huấn luyện Random Forest/SVM ở Tuần 4. Cần lưu ý xử lý outlier độ dài và mất cân bằng lớp đúng như kế hoạch đã định trước khi huấn luyện.